

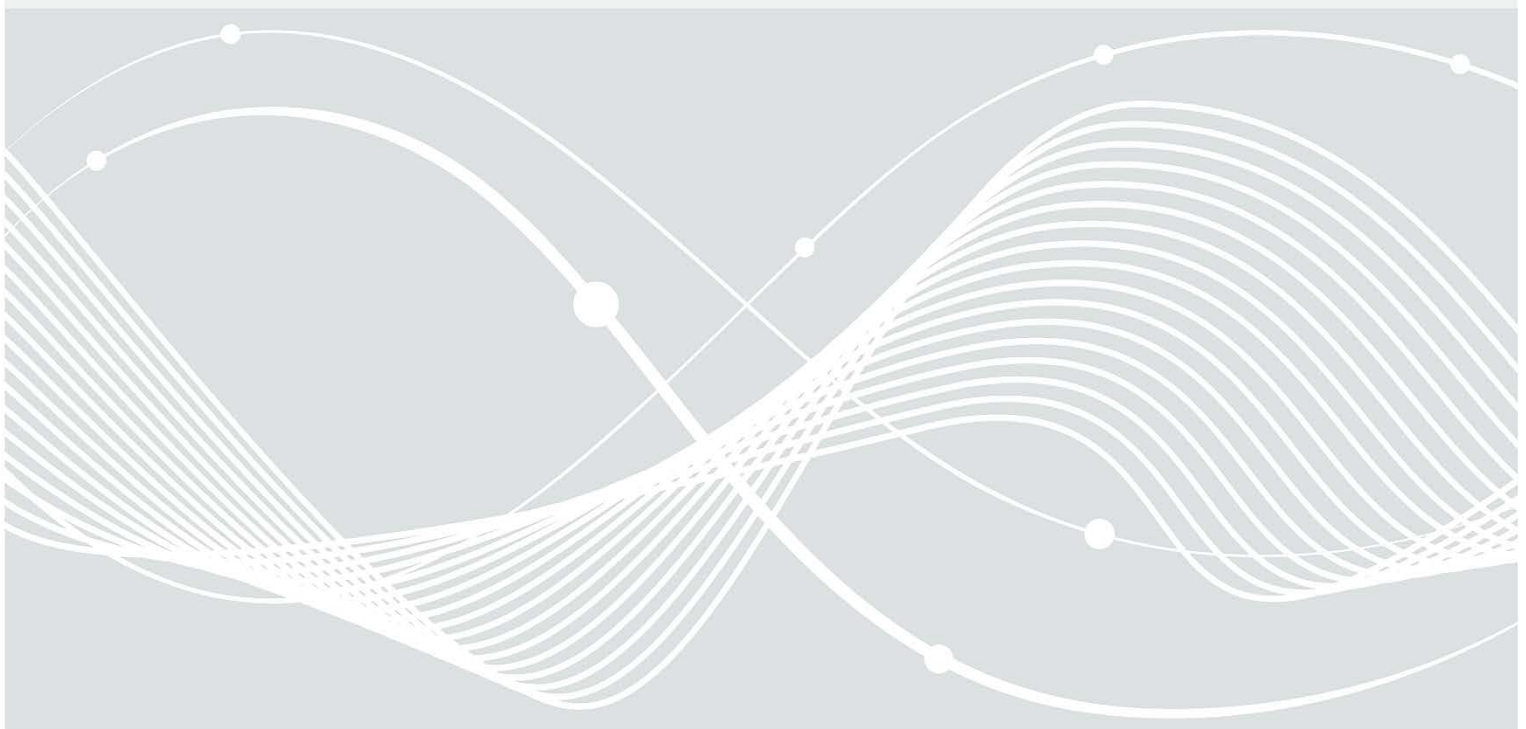


Federal Office
for Information Security

BSI TR-03173: Amendments for Conformance Assessments based on ETSI EN 303 645/TS 103 701

Version: 1.11

Date: 19/01/2026



Document history

<i>Version</i>	<i>Date</i>	<i>Editor</i>	<i>Description</i>
1.0	27/04/2022	BSI	Public Release Version
1.1	31/07/2025	BSI	Alignment with ETSI EN 303 645 v3.1.3 and ETSI TS 103 701 v2.1.1
1.11	19/01/2026	BSI	• Change from SOG-IS to ACM • Crypto legacy extension.

Table 1: Document history

Key Words

The key words “MUST”, “MUST NOT”, “REQUIRED”, “SHALL”, “SHALL NOT”, “SHOULD”, “SHOULD NOT”, “RECOMMENDED”, “MAY”, and “OPTIONAL” in this document are to be interpreted as described in IETF RFC 2119 [1]. The key word “CONDITIONAL” is to be interpreted as follows:

CONDITIONAL: The usage of an item is dependent on the usage of other items. It is therefore further qualified under which conditions the item is REQUIRED or RECOMMENDED.

Table of Contents

1 Introduction..... 5

2 Amendments..... 6

 2.1 Best Practice Cryptography..... 6

 2.2 Usability..... 6

 2.3 Secure Storage 7

 2.4 Additional Applications..... 7

Bibliography 8

1 Introduction

The European standard “Cyber Security for Consumer Internet of Things: Baseline Requirements” (ETSI EN 303 645) [2] provides a set of baseline provisions for consumer IoT devices. The corresponding assessment specification “Cyber Security for Consumer Internet of Things: Conformance Assessment of Baseline Requirements” (ETSI TS 103 701) [3] specifies a conformance assessment methodology. These documents are essential to understand and apply the present document. Manufacturers can consult the “Guide to Cyber Security for Consumer Internet of Things” (ETSI TR 103 621) [4] for implementation examples concerning the requirements of ETSI EN 303 645 [2].

Due to the generic character of ETSI EN 303 645 [2] and ETSI TS 103 701 [3] some amendments are necessary for the performance of a conformance assessment (see section 4.8 of ETSI TS 103 701 [3]) which are covered by the present document. Therefore, BSI provides for each published version of ETSI EN 303 645 and the corresponding ETSI TS 103 701 an associated version of the present document. The present document belongs to **ETSI EN 303 645 v3.1.3** and **ETSI TS 103 701 v2.1.1**.

For example, the IT Security Label includes such a conformance assessment, where these amendments are applied. The IT Security Label allows manufacturers to label their IT products assuring those products have certain security features. This is accomplished by a self-declaration on the base of recognized security standards. The self-declaration is supplemented by a down-streamed process of market surveillance in which the BSI performs a random or event-based check, to evaluate if the product does match the security features declared by the manufacturer.

2 Amendments

2.1 Best Practice Cryptography

The amendments in this section address the following provision of ETSI EN 303 645 [2] concerning “best practice cryptography” and “encryption appropriate to the properties of the technology, risk and usage.” for:

- Provision 5.1-3: User Authentication
- Provision 5.3-7: Secure Update
- Provision 5.5-1 and 5.5-6: Secure Communication
- Provision 5.8-1 and 5.8-2: Ensure that personal data is secure

The standard ETSI EN 303 645 [2] does not contain specific cryptographic requirements. ETSI TS 103 701 [3] provides a methodology to assess whether cryptography can be considered as best practice with respect to the use case based upon reference catalogues or alternative evidences. Within this methodology only the following documents **shall** be used as reference catalogues:

- ECCG ACM [5] with the following deviation for consumer IoT devices and associated services:
The acceptability deadline for the legacy use of modulus of size above 1900 bits, but less than 3000 bits, is set to December 31, 2027
- BSI TR-02102-1/2/3/4 [6] [7] [8] [9]

NOTE 1: For references without version numbers, the currently published version of the referenced document applies.

NOTE 2: The catalogues contain also cryptographic requirements or recommendations for use cases requiring security beyond the level basic.

NOTE 3: The methodology of ETSI TS 103 701 [3] allows to provide evidences to justify that the used cryptography is to be considered as best practice cryptography besides the listing in the reference catalogues.

NOTE 4: This amendment does not replace the methodology of ETSI TS 103 701 [3]. Only the term “reference catalogue” is concretised. Apart from that, the test groups concerning best practice cryptography apply unchanged as described in ETSI TS 103 701 [3].

Concerning the examination of cryptography defined in the methodology in ETSI TS 103 701 [3], the following non-exhaustive list of primitives and communication protocols **shall** be considered as known to be vulnerable to a feasible attack:

- SSL, TLS 1.0, TLS 1.1 for the use cases of communication with associated web services
- WEP for the use cases of Wi-Fi communication

2.2 Usability

The amendments in this section address the following provision of ETSI EN 303 645 [2] concerning usability:

- Provision 5.1-4: Changing authentication value
- Provision 5.3-3: Simple application of updates
- Provision 5.3-13: Publication of support period
- Provision 5.3-14: Publication of support period and replacement support for constraint devices
- Provision 5.8-3: Documentation of external sensing capabilities
- Provision 5.11-1: Erasing user data
- Provision 5.11-2: Removing personal data from associated service
- Provision 5.12-1: Installation and maintenance decisions

The test cases in ETSI TS 103 701 [3] regarding the listed provisions refer to a “user with limited technical knowledge” to assess whether usability is given in the context of the provision. The model “user with limited technical knowledge” in Annex D.3 from ETSI TS 103 701 [3] **shall** be used for the related test cases.

2.3 Secure Storage

The amendments in this section address the following provision of ETSI EN 303 645 [2] concerning secure storage:

- Provision 5.4-1: Secure storage of sensitive security parameters

The test cases in ETSI TS 103 701 [3] regarding the listed provision refer to “suitable protection mechanism for the claimed security guarantees”. The “baseline attacker model” in Annex D.2 from ETSI TS 103 701 [3] **shall** be used for the related test cases to assess whether protection mechanisms are suitable for the claimed security guarantees.

2.4 Additional Applications

An IoT device can provide the capability to operate additional applications (first- and third-party apps). This is a special case which is not in the focus of ETSI EN 303 645 [2].

Preinstalled applications on an IoT device are to be considered as part of the Device under Test (DUT see ETSI TS 103 701 [3]).

The security of the applications on the DUT, which are installed by the user after initialization, are not part of the assessment. This includes applications, which are deactivated by default or prepared for installation (e.g., links to an app store). However, the interaction between the DUT and such types of application is addressed. The following clarifications apply:

Provision 5.4-1: Secure storage of sensitive security parameters

Consider the interaction of the application with the DUT concerning “Security Guarantees” and “Protection Schemes” (see ETSI TS 103 701 [3]).

Bibliography

- [1] IETF RFC 2119: Key words for use in RFCs to Indicate Requirement Levels.
- [2] ETSI EN 303 645: Cyber Security for Consumer Internet of Things: Baseline Requirements v3.1.3.
- [3] ETSI TS 103 701: Cyber Security for Consumer Internet of Things: Conformance Assessment of Baseline Requirements v2.1.1.
- [4] ETSI TR 103 621: Guide to Cyber Security for Consumer Internet of Things v2.1.1.
- [5] ECCG ACM: European Cybersecurity Certification Group Subgroup on Cryptography, Agreed Cryptographic Mechanisms Version 2.0.
- [6] BSI TR-02102-1: Cryptographic Mechanisms: Recommendations and Key Lengths
- [7] BSI TR-02102-2: Cryptographic Mechanisms: Use of Transport Layer Security (TLS)
- [8] BSI TR-02102-3: Cryptographic Mechanisms: Use of Internet Protocol Security (IPsec) and Internet Key Exchange (IKEv2)
- [9] BSI TR-02102-4: Cryptographic Mechanisms: Use of Secure Shell (SSH)

NOTE: For references without version numbers, the currently published version of the referenced document applies.